

RESTARTING

PRIMEIRAS ESTRATÉGIAS



2

LISTA DE FIGURAS

Figura 1 - Estruturação do processo da informação.....	6
Figura 2 - Princípios da inteligência	8
Figura 3 - Engenharia Social	10
Figura 4 - O elemento mais vulnerável é o ser humano	13
Figura 5 - Fases de um ataque de Engenharia Social	14
Figura 6 - Diferença entre Phishing e Spear Phishing.....	16
Figura 7 - Pharming.....	17

EXEMPLO

SUMÁRIO

PRINCÍPIOS DA INTELIGÊNCIA.....	4
1 INTRODUÇÃO	4
2 PRINCÍPIOS DE INTELIGÊNCIA.....	4
2.1 Inteligência e contrainteligência	5
2.2 O conhecimento de inteligência	6
2.3 Princípios básicos da inteligência.....	7
2.4 Segurança como valor estratégico	8
3 ENGENHARIA SOCIAL.....	9
3.1 Engenharia social em ambientes corporativos	10
3.2 Conhecendo o elo mais fraco.....	11
3.3 Entendendo as técnicas de ataque	14
3.4 A engenharia social do ponto de vista da segurança da informação	19
3.5 Proteções contra a engenharia social	21
REFERÊNCIAS.....	23

PRINCÍPIOS DA INTELIGÊNCIA

1 INTRODUÇÃO

Neste capítulo, abordaremos a inteligência e a segurança como valores estratégicos, pois é certo que você será questionado sobre o nível de segurança do ambiente e da sua equipe. Essa segurança não depende apenas da tecnologia, mas também do comportamento humano, o elo mais frágil na cadeia de segurança cibernética.

2 PRINCÍPIOS DE INTELIGÊNCIA

A indefinição de ameaças, bem como o ressurgimento de fenômenos de grande repercussão nacional e internacional - o terrorismo, o crime organizado, a proliferação de ameaças no campo cibernético, tais como ataques, vazamento de dados e *insiders* – demandam respostas imediatas e pontuais com o mínimo de efeitos colaterais.

Para que uma empresa ou instituição possa atuar nesse ambiente difuso, é preciso compreender, o mais cedo possível, que a Segurança da Informação não é apenas um problema de TI. A cultura organizacional das corporações tende a deixar de lado os investimentos nessa área, ação que tem levado importantes empresas a colherem péssimos frutos.

Normas e procedimentos claros de segurança da informação devem ser seguidos por todos os usuários da empresa. Essa deve ser uma realidade coordenada como uma diretriz, e não apenas como uma informação, visto que a maior dificuldade das grandes organizações é garantir que todos os seus funcionários compreendam e sigam adequadamente as normas e políticas de segurança, reconhecendo sua importância e aplicando-as no dia a dia.

O entendimento e a aplicação dos conhecimentos em inteligência e contrainteligência são vitais para o modelo de negócios de qualquer empresa, principalmente na sua vertente preditiva, permitindo que a direção possa ter um

constante entendimento situacional, tanto das ameaças iminentes quanto das oportunidades de obtenção de vantagens comerciais.

2.1 Inteligência e contrainteligência

A atividade de inteligência envolve a geração de conhecimentos e dados, bem como a proteção daquelas informações que o Estado ou uma corporação têm interesse em manter em segurança. O foco principal é obter informações que possam oferecer uma vantagem política, estratégica ou comercial em relação à concorrência, ou que contribuam para aumentar a segurança dos dados valiosos.

Desdobra-se em dois grandes segmentos: de Inteligência - objetivamente voltado para a produção de conhecimentos, e de Contrainteligência - objetivamente voltado para a salvaguarda de conhecimentos (Brasil, 2007).

Carmo (2011), em seu artigo “A Guerra Cibernética e a Contrainteligência Virtual”, analisa os impactos da inteligência e contrainteligência no espaço cibernético. Segundo o autor, o mundo passou a conviver com uma série de ameaças que transitam entre o simples prazer de vencer barreiras de sistemas, sem maldade explícita, pelos crimes agora revestidos e suportados por meios computacionais, até aquelas com o propósito claro ou velado de causar danos e expor Estados e organizações.

Sob este aspecto, identificar a origem desses atos, em face da capilaridade da rede mundial de computadores, é uma tarefa árdua, principalmente por ser um campo em que não se define claramente o conceito de “fronteira”.

Conforme cita Pereira (2011), as fronteiras nacionais ficaram permeáveis, o que foi acentuado com o advento da Tecnologia de Informação, uma vez que a internet condiciona o mundo, impossibilitando que qualquer país tenha total fluxo de capital. Dessa maneira, tudo está na rede, incluindo economias e crimes.

Em outras palavras, não basta, para uma organização, possuir um time de defesa cibernética que domine os aspectos técnicos. Se ela não possuir a cultura de inteligência e contrainteligência atreladas ao seu Plano de Segurança Cibernética (ou ainda ao seu Plano de Negócios), seus dados de valor não estariam somente vulneráveis, mas também suas oportunidades de obtenção de vantagens em relação

à concorrência seriam escassas ou nulas, uma vez que os dados de diversas organizações estão expostos de maneira insegura na internet e/ou as barreiras de proteção desses dados são temporárias.

2.2 O conhecimento de inteligência

Segundo Setzer (1999), podemos definir “dado” como uma sequência de símbolos quantificados ou quantificáveis, como letras, imagens, sons etc., pois todos podem ser quantificados a tal ponto que alguém que os tenha em contato possa, eventualmente, ter dificuldade em distinguir a sua reprodução, originada da representação quantificada, do original. É fundamental observar que qualquer texto é, por si só, um dado ou uma sequência de dados, mesmo que seja incompreensível para o leitor.

Por sua vez, a informação é uma abstração informal que representa algo significativo para alguém por meio dos dados (textos, imagens, sons etc.). A frase “Paris é uma cidade fascinante” é um exemplo de informação - desde que seja lida ou ouvida por alguém e que “Paris” signifique a capital da França e “fascinante” tenha a qualidade usual e intuitiva associada com aquela palavra.

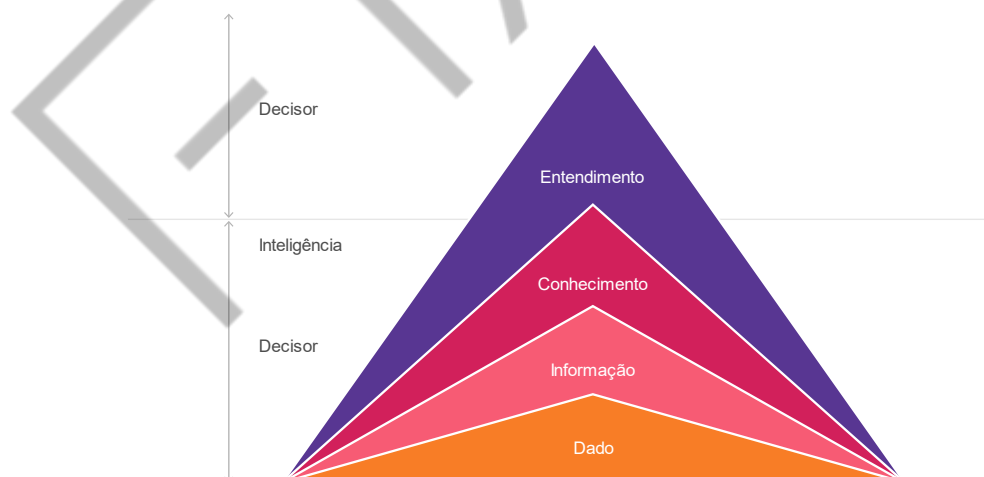


Figura 1 - Estruturação do processo da informação
Fonte: Elaborado pelo autor (2019)

O correto entendimento do dado processado é essencial para o planejamento e execução das tomadas de ação em uma organização, desde o nível operacional até o nível de direção. As informações são o resultado do processamento, da manipulação e da organização de dados.

Essas informações, se consideradas relevantes, são analisadas e transformadas em conhecimento. Esse conhecimento é fundamental para que os decisores possam ter um melhor entendimento da situação, contribuindo para a obtenção da necessária consciência situacional.

2.3 Princípios básicos da inteligência

A seguir tem-se os princípios que devem nortear a atividade de inteligência em uma organização:

- 1 **Segurança:** em todas as fases de sua produção, o conhecimento deve ser protegido de forma que o seu acesso seja limitado apenas às pessoas credenciadas.
- 2 **Objetividade:** para que seja útil, o conhecimento deve ter sua produção orientada a objetivos claramente definidos.
- 3 **Clareza:** os conhecimentos produzidos devem ser expressos de forma a receberem imediata e completa compreensão por parte dos receptores.
- 4 **Imparcialidade:** a produção de conhecimento deve se distanciar das ideias preconcebidas, dos subjetivismos e de outras influências que possam gerar desvios ou distrações.
- 5 **Precisão:** deve-se procurar atingir o maior grau de exatidão da obtenção de dados e na produção de conhecimentos.
- 6 **Continuidade:** a necessidade de conhecimento é permanente; as atividades de inteligência e contrainteligência são executadas constante e ininterruptamente.
- 7 **Predição:** a inteligência deve fornecer informações sobre o que as ameaças e oportunidades podem causar, buscando sempre antecipar-se a elas.



Figura 2 - Princípios da inteligência
Fonte: Tirotti-Periciais Judiciais (2019)

2.4 Segurança como valor estratégico

De acordo com Côrtes (2014), assim como qualquer ativo de valor, a informação também necessita de proteção. No entanto, toda proteção envolve um custo e, por isso, ao determinar o nível de proteção a ser atribuído à informação, é importante considerar a seguinte expressão:

$$\text{Valor da Informação} \geq \text{Custo da Proteção}$$

Para satisfazer essa expressão, é necessário conhecer tanto o valor da informação quanto o custo de sua proteção. O custo da proteção está relacionado com os recursos tangíveis a serem utilizados, tais como: tecnológicos, materiais e humanos. Por um lado, o seu cálculo, embora não trivial, é passível de ser estabelecido; por outro, determinar o valor da informação é algo de razoável complexidade, pois se trata de atribuir valor a um ativo intangível (Côrtes, 2014).

Assim sendo, quando não se atribui nenhum valor à informação ou lhe atribui valor inadequado, a proteção dela pode se tornar inconsistente. É similar ao que ocorre na construção civil, onde, para calcular as dimensões dos pilares, é necessário saber, previamente, qual será a carga que eles precisarão suportar. O cálculo começa de cima para baixo: primeiro calcula-se a carga que a laje deverá suportar (valor da informação) e depois dimensionam-se os pilares que suportarão aquela carga (segurança da informação). Quando não se sabe qual a carga que será colocada sobre a laje, como dimensionar os pilares? Eles podem ficar super ou subdimensionados. Da mesma forma, quando não se estima o valor da informação, a proteção poderá ficar super ou subdimensionada.

No primeiro caso, os custos com a implementação dos requisitos de proteção estabelecidos podem ser maiores do que o próprio valor da informação e, assim, gerar gastos desnecessários. No segundo caso, os requisitos de proteção podem estar aquém do valor da informação (Côrtes, 2014).

Portanto, definir o nível de proteção que se pretende dar à informação é muito mais assertivo quando ela passa por um processo de classificação.

O Governo Federal classificou e estabeleceu o prazo de restrição da informação com base na Lei de Acesso à Informação:

Art. 24. A informação em poder dos órgãos e entidades públicas, observado o seu teor e em razão de sua imprescindibilidade à segurança da sociedade ou do Estado, poderá ser classificada como ultrassecreta, secreta ou reservada.

§1º Os prazos máximos de restrição de acesso à informação, conforme a classificação prevista no caput, vigoram a partir da data de sua produção e são os seguintes:

I - ultrassecreta: 25 (vinte e cinco) anos;

II - secreta: 15 (quinze) anos; e

III - reservada: 5 (cinco) anos (Brasil, 2011).

Essa classificação demonstra que as diversas informações de uma organização assumem valores diferenciados, cabendo ao gestor a responsabilidade de estabelecer a proteção compatível com o valor ou com o grau de sigilo de cada grupo de informação (Côrtes, 2014).

3 ENGENHARIA SOCIAL

Viver em um mundo conectado, em que todas as atividades cotidianas são permeadas pela tecnologia, apesar de trazer incríveis benefícios, como automatizações de processos, facilidade de acesso à informação de forma ágil e continuada, possibilidade de comprar e efetuar pagamentos sem sair de casa ou ainda não ter que andar com dinheiro físico, também nos expõe a riscos que, muitas vezes, não concebemos.

3.1 Engenharia social em ambientes corporativos

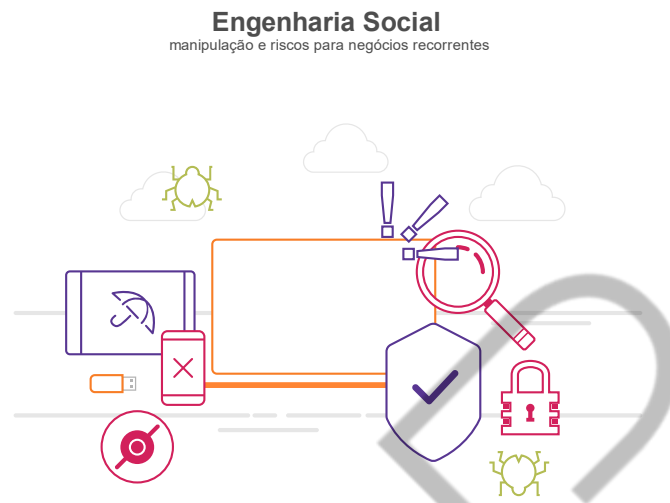


Figura 3 - Engenharia Social
Fonte: Super lógica (2019)

Ao ouvir sobre golpes na internet, fraudes eletrônicas, roubo e vazamento de dados, imaginamos que os alvos destes tipos de ataques são, em sua maioria, empresas e instituições de governos que possuem dados valiosos ou segredos comerciais. Porém, esquecemos que toda organização, e aqui entenda Pessoa Jurídica, é constituída por pessoas que, assim como nós, têm seus dados expostos de forma displicente na internet.

Outro fator preponderante nesse cenário é que, assim como pessoas precisam de outras para estabelecer relações dos mais diversos tipos, em um mundo conectado, empresas também dependem de outras para sobreviver, sejam fornecedores, parceiros comerciais, revendedores e até concorrentes.

Mas o que tudo isso tem a ver com engenharia social? Esse termo está relacionado com as práticas para obter acesso a informações importantes ou sigilosas em organizações ou sistemas, por meio da enganação ou exploração da confiança das pessoas. Ela utiliza-se de conhecimentos empíricos e científicos das relações humanas com o intuito de manipular uma vítima a fim de obter informações confidenciais e dados negados de forma explícita dessa vítima, bem como dos círculos sociais e corporativos em que ela esteja inserida.

A *Verizon*, uma das principais empresas no ramo de segurança digital, divulgou em seu mais recente relatório anual sobre investigação de violação de dados informações interessantes: 62% dos incidentes com motivação financeira

envolveram *ransomware* ou extorsão; 68% das violações envolveram o elemento humano não malicioso, como uma pessoa que foi vítima de um ataque de engenharia social ou que cometeu um erro e 14% das violações envolveram a exploração de vulnerabilidades como uma etapa de acesso inicial, quase o triplo da quantidade do relatório do ano passado (Verizon, 2024, tradução nossa).

Imaginemos uma empresa X que se preocupa com Segurança da Informação e investe pesado em ativos de segurança, *appliances* de *Firewall*, sistemas de autenticação centralizada, licenças de antivírus etc. Essa empresa ainda contrata rotineiramente times de análise de vulnerabilidades para testarem suas brechas, com o intuito de uma melhoria contínua da segurança dos seus dados. Na sua concepção, essa empresa estaria segura contra ataques de engenharia social? Posso lhe afirmar seguramente: não!

Kevin Mitnick (2003), um dos maiores hackers da história, preso em 1995 por uma ação conjunta do FBI com a NSA, é autor do *Best Seller* “A Arte de Enganar”. Ele afirma que “não existe tecnologia no mundo que evite o ataque de um engenheiro social” e que o elo mais fraco em qualquer ecossistema de segurança somos nós: os seres humanos.

Seu livro está recheado de casos reais de hackers e engenheiros sociais (sim, nem todo engenheiro social é um hacker, pois em alguns cenários não é necessário conhecimento de informática para explorar vulnerabilidades em pessoas) que tiveram êxito em ações contra grandes empresas por manipularem simples funcionários. Nesses casos, as pessoas exploradas não tinham noção de que a informação aparentemente irrelevante, naquele momento, que estava sendo compartilhada com elas era, na verdade, mais uma peça de um grande quebra-cabeça que o engenheiro social estava montando com o objetivo de realizar uma ação ainda mais significativa.

3.2 Conhecendo o elo mais fraco

O comportamento do ser humano é decisivo para um ataque de engenharia social, pois é por intermédio dele que são reconhecidas as vulnerabilidades em cada indivíduo.

De acordo com Coelho (2008), o ser humano possui características psico-comportamentais que o tornam suscetível a ataques, sendo elas:

- **Vaidade pessoal e/ou profissional:** o ser humano costuma ser mais receptivo a uma avaliação positiva e favorável aos seus objetivos, aceitando basicamente argumentos favoráveis a sua avaliação pessoal ou profissional ligada diretamente ao benefício próprio ou coletivo de forma demonstrativa.
- **Autoconfiança:** o ser humano busca transmitir em diálogos individuais ou coletivos o ato de fazer algo bem, buscando transmitir segurança, conhecimento, saber e eficiência, criando uma estrutura base para o início de uma comunicação ou ação favorável a uma organização ou indivíduo.
- **Formação profissional:** o ser humano tende a valorizar sua formação e as habilidades adquiridas, visando exercer controle sobre a comunicação, execução ou apresentação, seja em contextos profissionais ou pessoais, frequentemente buscando, de forma inconsciente, o reconhecimento pessoal como objetivo principal.
- **Vontade de ser útil:** o ser humano, comumente, procura agir com cortesia e ajudar os outros quando necessário.
- **Busca por novas amizades:** o ser humano costuma se agradar e sentir-se bem quando elogiado, ficando mais vulnerável e aberto a dar informações.
- **Propagação de responsabilidade:** trata-se da situação na qual o ser humano considera que ele não é o único responsável por um conjunto de atividades.
- **Persuasão:** compreende quase uma arte a capacidade de persuadir pessoas; busca-se obter respostas específicas. Isso é possível porque os indivíduos possuem características comportamentais que os tornam vulneráveis à manipulação.

Por meio da exploração dessas características, engenheiros sociais conseguem obter informações de instituições sem precisar invadir sistemas de segurança, roubar dados ou implantar *malwares*. Em outras palavras, um

engenheiro social não necessita de meios tecnológicos para deferir um ataque, por mais que o uso da tecnologia possa potencializar determinados tipos.

Analizando uma ação de engenharia social do ponto de vista da inteligência corporativa, uma organização pode utilizar-se de técnicas com o intuito de obter dados relevantes de seus concorrentes, explorando o comportamento humano dos funcionários da empresa vítima ou ainda dos seus próprios executivos.



Figura 4 - O elemento mais vulnerável é o ser humano
Fonte: Google Imagens (2019)

Imagine um cenário no qual uma empresa necessita obter informações sobre o lançamento de um produto de seu concorrente. Com esse objetivo, ela contrata um veículo de mídia para liberar informações falsas de que seu novo produto, ainda em fase de desenvolvimento, possuirá uma tecnologia inovadora, que sabidamente não existe. Os executivos de sua concorrente, ao terem acesso a tais informações por intermédio dos veículos de mídia, se desesperam com a possibilidade de lançarem um produto inferior no mercado e divulgam informações, até então sigilosas, sobre as novidades que seu produto trará ao mercado. Com esta ação, a empresa atacante conseguiu descobrir o que queria explorando a vaidade profissional dos executivos da empresa vítima e terá melhores condições na corrida de mercado para lançar produtos.

Note que simples ações, costumeiramente factíveis, são bons casos do uso da engenharia social. São inúmeros os casos desses tipos de ataques que ocorrem diariamente e nós, pessoas comuns, somos potenciais vítimas de pequenos ataques envolvendo algo maior.

3.3 Entendendo as técnicas de ataque

De acordo com Thapar (2007), existem duas categorias principais de ataques envolvendo engenharia social.



Figura 5 - Fases de um ataque de Engenharia Social
Fonte: Elaborado pelo autor (2019)

- **Ataques com uso de tecnologia:** quando o usuário é explorado fazendo-o acreditar que está interagindo com uma aplicação ou sistema verídico e, com isso, ele fornece informações confidenciais, como logins e senhas, dados de cartão de crédito e pagamento, dados pessoais, endereço etc.
- **Ataques sem uso de tecnologia:** o engenheiro social manipula a vítima aproveitando-se dos pontos fracos do comportamento humano. Um caso bem usual é quando o atacante se passa por um sequestrador e liga para uma vítima, geralmente aleatória, informando que está de posse de um de seus entes queridos e que só o(a) libertará após o pagamento de um resgate. Utilizando-se da persuasão e de efeitos sonoros, como uma outra pessoa se passando pelo(a) sequestrado(a), o atacante consegue convencer a vítima a efetuar o pagamento.

No que tange aos ataques com uso de tecnologia, Thapar (2007) enumera os principais tipos. Vejamos:

- **Phishing:**

Este é talvez o ataque mais comum. Geralmente realizado por meio de um e-mail à vítima, que parece ter vindo de um remetente legítimo, como uma empresa de cartão de crédito solicitando "verificação" de informações por motivos de segurança. O e-mail normalmente contém um link para uma página web fraudulenta, que se

assemelha com a página legítima, incluindo logotipos e conteúdo da empresa verdadeira, contendo um formulário para o usuário informar seu login, senha, número de cartão de crédito, código de segurança etc.

- **Software interessante:**

Neste caso, a vítima é convencida a efetuar o *download* e instalar um aplicativo muito útil, como um acelerador de desempenho da CPU, um ótimo utilitário do sistema ou um *crack* para um *software* muito caro. Um programa malicioso, como um *spyware* ou um *malware*, é instalado na máquina da vítima.

- **Mensagens de spam:**

E-mails que oferecem amizades, diversão, presentes, descontos ou fotos comprometedoras de celebridades são rotineiramente enviados sob demanda com o intuito de instalar códigos maliciosos quando a vítima interage com o link ou anexo destes e-mails. No caso de um funcionário de uma empresa, ao executar esta ação dentro da rede corporativa, poderá colocar em risco toda a segurança da rede, bem como dos dados trafegados.

- **Vishing:**

Esta é uma técnica que utiliza o telefone como vetor de ataque. Levando-se em conta a tecnologia VoIP (*Voice over IP*), os atacantes utilizam-se de servidores VoIP (próprios ou invadidos) para realizarem ataques de *phishing* por telefone, por intermédio de falsificação da identificação de chamada, automação dos processos de ligação e atendimento telefônico e outros mecanismos amplamente difundidos, que podem ser implantados em computadores convencionais.

Um ataque de *vishing* geralmente é deflagrado tendo-se como objetivo a obtenção de dados financeiros da vítima, como cartões de crédito, senhas de banco etc.

- **Spear Phishing:**

Este é um conceito relativamente novo no mercado do cibercrime. De acordo com os pesquisadores da *Kaspersky* (s.d.), uma das maiores distribuidoras de *softwares* antivírus do mundo, *Spear phishing* é um golpe de e-mail direcionado com o objetivo único de obter acesso não autorizado aos dados sigilosos. Diferente dos golpes de *phishing*, que realizam ataques amplos e dispersos, esse foca em um grupo ou em uma organização específica. A intenção é roubar propriedade intelectual, dados financeiros, segredos comerciais, industriais ou militares e outros dados confidenciais.

Ele funciona da seguinte maneira: um e-mail é recebido, aparentemente de uma fonte confiável, mas leva o destinatário a um site falso cheio de *malware*. Esses e-mails costumam usar táticas inteligentes para chamar a atenção das vítimas. O FBI alertou sobre golpes de *spear phishing*, nos quais os e-mails pareciam ser do *National Center for Missing and Exploited Children*, por exemplo.

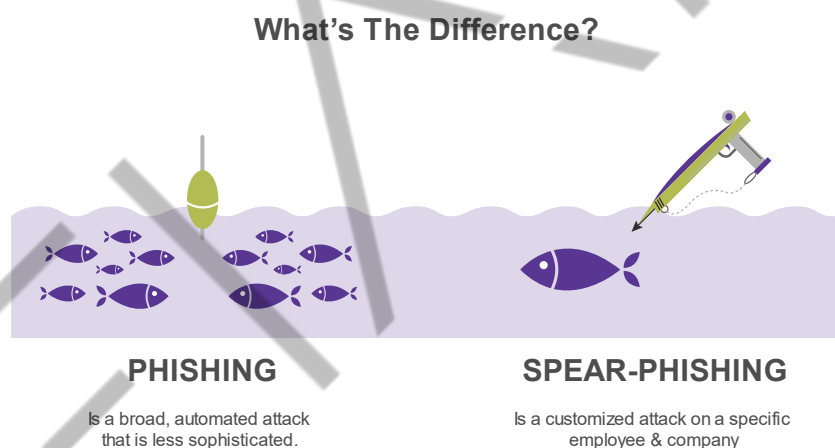


Figura 6 - Diferença entre Phishing e Spear Phishing
Fonte: Google Imagens (2019)

Muitas vezes, hackers e hacktivistas patrocinados pelo governo estão por trás desses ataques. Os criminosos virtuais fazem o mesmo com a intenção de revender dados confidenciais para governos e empresas privadas. Esses criminosos virtuais utilizam abordagens criadas individualmente e técnicas de engenharia social para personalizar mensagens e sites com eficiência.

Como consequência, mesmo alvos de alto escalão dentro das organizações, como altos executivos, podem abrir e-mails que acreditam ser seguros. Esse deslize permite que os criminosos virtuais roubem os dados necessários para atacar suas redes.

- **Pharming:**

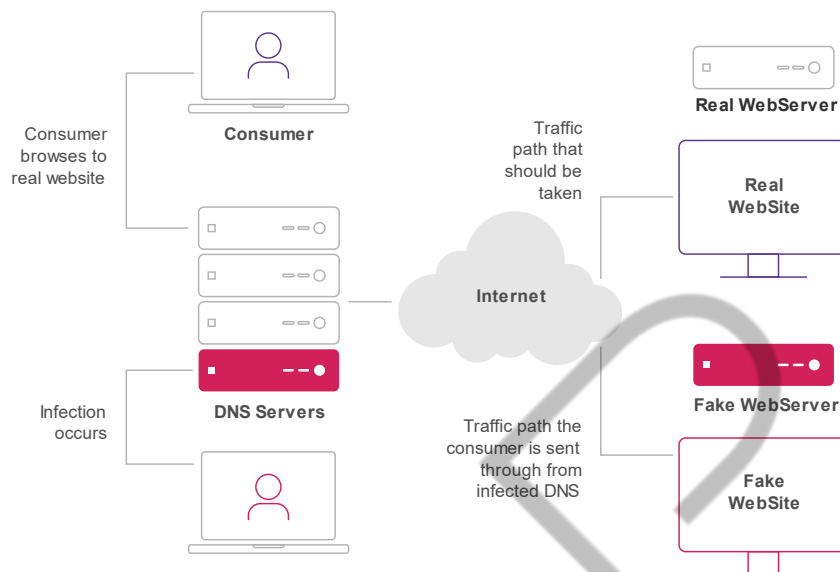


Figura 7 - Pharming
Fonte: Google Imagens (2019)

Assim como o *spear phishing*, o *pharming* é um novo conceito que tem ganhado notoriedade na internet e, dos ataques de engenharia social, ele é sem dúvida o que mais se utiliza de tecnologia. Nele, o atacante “envenena” um sistema de DNS (geralmente o ataque é realizado contra roteadores caseiros, em que o atacante consegue acesso ao DNS interno dos roteadores e cria entradas falsas), fazendo com que o usuário que deseja acessar uma URL válida receba uma cópia do site desejado por meio de outro servidor falso (em um ambiente de hospedagem controlado pelo atacante). Nesse ponto, a vítima tem certeza de estar acessando um site legítimo e acaba enviando dados pessoais, como logins e senhas, e dados financeiros.

- **Baiting:**

Por meio dessa técnica, hackers deixam à disposição do usuário um dispositivo infectado com *malware*, como um pen-drive ou um CD. A intenção é despertar a curiosidade do indivíduo para que insira o dispositivo em uma máquina a fim de checar seu conteúdo.

O sucesso dos ataques de *baiting* depende de três ações do indivíduo: encontrar o dispositivo, abrir seu conteúdo e instalar o *malware* sem perceber. Uma vez instalado, o *malware* permite que o hacker tenha acesso aos sistemas da vítima.

A tática envolve pouco trabalho por parte do hacker. Tudo o que ele precisa fazer é infectar um dispositivo e ocasionalmente deixá-lo à vista do alvo, seja na entrada ou no interior dos escritórios. O dispositivo pode ser, por exemplo, um pen-drive contendo um arquivo com nome “chamativo”, como “folha salarial 2017” (Proof, 2018).

- ***Pretexting:***

Por meio do *pretexting*, os hackers fabricam falsas circunstâncias para coagir a vítima a oferecer acesso a informações e sistemas críticos. Nesse caso, os hackers assumem uma nova identidade ou papel para se passarem por alguém de confiança da vítima.

Tudo o que o cibercriminoso precisa é dar uma olhada nos perfis da vítima nas redes sociais para descobrir informações como data e local de nascimento, empresa, cargo, nomes de parentes, colegas de trabalho, amigos, entre outros. Depois, basta enviar um e-mail (ou outro tipo de comunicação) à vítima fingindo a necessidade de confirmar dados para garantir seu acesso a algum sistema específico. Pode ser, por exemplo, um e-mail supostamente da equipe de TI coagindo a vítima a divulgar suas credenciais (Proof, 2018).

- ***Quid pro quo:***

Um ataque de *quid pro quo* ocorre quando um hacker requer informações privadas de alguém em troca de algo. “*Quid pro quo*” basicamente significa “isso por aquilo”, em que o cibercriminoso oferece algo à vítima em troca de informações sensíveis.

A tática mais comum consiste em se fazer passar por um profissional de TI e abordar várias vítimas até encontrar alguém com um problema real de tecnologia. Sob a orientação do hacker, a vítima acaba fornecendo acesso a códigos,

desativando programas essenciais e instalando *malwares*, acreditando que está resolvendo a questão.

Outra tática bastante usada é a de simular uma pesquisa em que funcionários passam uma série de informações sensíveis em troca de brindes, como canetas e canecas (Proof, 2018).

- ***Tailgating:***

O *tailgating* é uma técnica física de engenharia social que ocorre quando indivíduos não autorizados seguem indivíduos autorizados até localizações seguras. O objetivo é obter ativos valiosos e informações confidenciais.

É o caso, por exemplo, de quando alguém pede para o outro “segurar a porta” porque esqueceu seu cartão de acesso ou quando pede seu smartphone ou computador emprestado para fazer “algo rapidinho”, mas na verdade instala *malwares* e rouba dados da máquina (Proof, 2018).

3.4 A engenharia social do ponto de vista da segurança da informação

“A informação representa a inteligência competitiva dos negócios e é reconhecida como ativo crítico para a continuidade operacional da empresa” (Peixoto, 2006, p. 37).

Conforme a ABNT (Associação Brasileira de Normas Técnicas), entendemos a necessidade de proteção da informação sob o seguinte aspecto:

A informação é um ativo que, como qualquer outro ativo importante, é essencial para os negócios de uma organização e, conseqüentemente, necessita ser adequadamente protegida. Isto é especialmente importante no ambiente dos negócios, cada vez mais interconectado. Como um resultado deste incrível aumento da interconectividade, a informação está agora exposta a um crescente número e a uma grande variedade de ameaças e vulnerabilidades (ABNT, 2005, p. 2).

Ainda de acordo com Peixoto (2006), a segurança da informação é formada por cinco pilares básicos: confidencialidade, integridade, disponibilidade, não repúdio e autenticidade, e eles também envolvem três aspectos principais: pessoas, processos e tecnologias.

O ser humano é um dos elementos mais importantes quando tratamos de segurança da informação. As pessoas se relacionam diretamente com a informação, visto que estão envolvidas com os processos de negócio, de modo que cada indivíduo é peça-chave para manter a segurança da informação (Silva, 2015).

Todos os dias, funcionários e colaboradores de organizações precisam lidar com informações. Além disso, os meios que armazenam ou trafegam dados também são manipulados por pessoas. Assim, para que a segurança da informação se torne possível, é necessário que as pessoas façam a sua parte com responsabilidade (Silva, 2015).

As organizações devem garantir que os colaboradores envolvidos compreendam suas responsabilidades no que concerne à segurança da informação, de modo a garantir a confidencialidade, integridade e disponibilidade da informação, já que, de modo geral, as pessoas não apresentam um bom entendimento do funcionamento das normas de segurança da informação ou das ameaças que estão suscetíveis (Casaca, 2014).

Pessoas mal-intencionadas podem estar vinculadas ou não a uma organização. Há também o caso particular de funcionários que já foram desligados da organização, mas ainda podem representar uma forte ameaça à segurança, uma vez que conhecem processos e sistemas da empresa. Pessoas que ainda estão vinculadas à organização podem levar informações sensíveis ao público por vários motivos, seja para ganho financeiro, insatisfação, entre outras motivações. Nas organizações pode-se encontrar pessoas de todos os perfis, por isso é importante que a segurança da informação dê uma atenção especial àqueles que possuem acesso a processos organizacionais da instituição (Silva, 2015).

De acordo com Mitnick (2006), grande parte das informações aparentemente inofensivas de uma empresa é altamente cobiçada por um engenheiro social, pois elas podem desempenhar um papel crucial em seu esforço para ganhar credibilidade e enganar vítimas. Em sua obra, Mitnick dá vários exemplos reais de ações de engenharia social e afirma que o grande trunfo de um atacante é ganhar acesso a informações que um empregado de uma empresa trata como inofensivas, quando na verdade não o são.

3.5 Proteções contra a engenharia social

Como vimos, um ataque de engenharia social sempre terá como alvo um ativo humano, independentemente de cargo, posição e hierarquia. Vimos também que esses ataques são como “jogos de quebra-cabeça”, em que o atacante reúne pedaços da informação (peças) com o intuito de ganhar credibilidade nos próximos ataques e obter os dados desejados. Porém, qual seria a forma mais eficaz de proteção contra esses ataques?

De acordo com Mitnick (2006), uma política de segurança bem desenvolvida, combinada com a educação e treinamentos adequados, aumenta bastante a consciência do empregado sobre o tratamento correto das informações comerciais corporativas. Uma política de classificação de dados ajuda a implementar os controles adequados para divulgação de informações. Sem essa política, todas as informações internas devem ser consideradas confidenciais, a menos que o contrário seja especificado. Além disso, o treinamento de segurança, no que se refere à política da empresa para proteger o ativo de informações, precisa ser aplicado a todos, e não apenas aos empregados que dispõem de acesso ao ativo de TI.

Um ponto a ser incluído no treinamento de segurança é o cuidado com o uso de “jargões”. Não é porque o interlocutor, visitante ou remetente do e-mail conhece os nomes de algumas pessoas da empresa, alguns jargões ou procedimentos corporativos, que ele é quem alega ser. E isso definitivamente não o estabelece como alguém autorizado a receber informações internas, nem acessar o sistema e/ou a rede da empresa.

O treinamento em segurança deve enfatizar que, quando estiver em dúvida, o empregado precisa verificar exaustivamente até ter certeza de que aquela pessoa pode ter acesso aos dados solicitados, mesmo que pareça ser inofensivo.

É preciso entender também que o acesso à informação vem sofrendo gradativas mudanças com o avanço tecnológico. Em tempos antigos, a grande maioria dos funcionários não tinha acesso à informação como um todo, necessitando apenas saber da sua parte dentro do escopo completo. Por exemplo,

em uma montadora de automóveis, determinado funcionário sabia que precisava colocar a peça X na posição Y e apertar os parafusos 307 e 309.

Com o avanço dos sistemas de informação, os funcionários precisaram ter acesso aos sistemas da empresa e entender mais a fundo sobre todo o seu funcionamento.

Por este motivo, a política de segurança de uma empresa precisa ser estendida a todos os funcionários, independentemente da posição. Todos devem entender que não são apenas os executivos e chefes que têm as informações que um atacante pode estar procurando. Hoje em dia, os empregados de todos os níveis, até mesmo aqueles que não usam computadores, podem ser alvos.

REFERÊNCIAS

ABNT. Associação Brasileira de Normas Técnicas. **NBR ISO/IEC 17799**: tecnologia da informação: técnicas de segurança - código de prática para a gestão da segurança da informação. Rio de Janeiro, 2005. 120 p. Disponível em: <<https://www.facom.ufu.br/~william/Disciplinas%202012-2/BSI%20-%20Auditoria%20e%20Seguranca/Material%20Adicional/NBR%20ISO-IEC%2017799-2005-PORTUGUES.pdf>>. Acesso em: 29 nov. 2024.

BRASIL. **Lei nº 12.527, de 18 de novembro de 2011**. Regula o acesso a informações previsto no inciso XXXIII do art. 5º, no inciso II do § 3º do art. 37 e no § 2º do art. 216 da Constituição Federal; altera a Lei nº 8.112, de 11 de dezembro de 1990; revoga a Lei nº 11.111, de 5 de maio de 2005, e dispositivos da Lei nº 8.159, de 8 de janeiro de 1991; e dá outras providências. Brasília, DF: Diário Oficial da União, 18 novembro de 2011. Disponível em: <<http://pesquisa.in.gov.br/imprensa/jsp/visualiza/index.jsp?jornal=1000&pagina=1&data=18/11/2011>>. Acesso em: 29 nov. 2024.

BRASIL. Ministério da Defesa. Estado-maior de defesa. Assessoria de doutrina e legislação. **Glossário das Forças Armadas**. Brasília, 2007.

CARMO, E. K. **A Guerra Cibernética e a Contraineligência Virtual**. Rio de Janeiro: ESG, 2011.

CASACA, J. A. **Gestão do Risco na Segurança da Informação**: Conceitos e Metodologias. Createspace Independent Pub, 2014.

COELHO, P. C. **Contraineligência em segurança pública**. São Paulo: Clube de autores, 2008.

CÔRTEZ, K. **Segurança da Informação baseada no valor da informação e nos pilares da tecnologia, pessoas e processos**. Brasília: Universidade de Brasília, 2014.

KASPERSKY. **O que é um Spear Phishing?** Disponível em <<https://www.kaspersky.com.br/resource-center/definitions/spear-phishing>>. Acesso em: 24 nov. 2024.

MITNICK, K. **A Arte de Enganar**. São Paulo: Makron/Pearson, 2003.

PEIXOTO, M. C. P. Engenharia Social e Segurança da Informação na Gestão Corporativa. Rio de Janeiro: Brasport, 2006.

PEREIRA, A. C. A. Elementos do Direito Internacional e Relações Internacionais. In: **Conferência para o curso de altos estudos de Política e Estratégia**, 2011, Rio de Janeiro, RJ. Apresentação... Rio de Janeiro: ESG, 2011.

SETZER, W. W. Dado, Informação, Conhecimento e Competência. **DataGramZero – Revista de Ciência da Informação**, n. zero, 1999. Disponível em: <<https://www.ime.usp.br/~vwsetzer/datagrama.html>>. Acesso em: 29 nov. 2024.

SILVA, C. A. **O Elo Mais Fraco da Segurança da Informação**: pessoas representam o maior desafio. Edição do Kindle, 2015.

VERISON.	2024	Data	Breach
Investigations	Report.	2023.	Disponível em:
< https://www.verizon.com/business/resources/reports/dbir/ >. Acesso em: 29 nov. 2024.			

